

Vertrag zur Auftragsverarbeitung gemäß Art. 28 DS-GVO

Zwischen dem/der

Schaufler Tooling GmbH & Co. KG, Goethestraße 72, 89150 Laichingen, vertreten durch die Geschäftsführung

– Verantwortlicher – nachstehend Auftraggeber genannt –

und dem/der

Prozessia GbR, Campus Starterzentrum Gebäude A1 1, 66123 Saarbrücken, vertreten durch Mohamed-Amin Douioui und Sebastian Spuhler

– Auftragsverarbeiter – nachstehend Auftragnehmer genannt –

1. Gegenstand und Dauer des Vertrags

(1) Gegenstand

Gegenstand des Vertrags zum Datenumgang ist die Durchführung folgender Aufgaben durch den Auftragnehmer: Entwicklung, Bereitstellung und Betrieb eines softwarebasierten „Beschaffungsagenten“ zur (teil-)automatisierten Verarbeitung von Beschaffungsdokumenten (u. a. Auftragsbestätigungen, Lieferscheine, Versanddokumente) des Auftraggebers, einschließlich Dokumentenerkennung/-extraktion und Abgleich mit dem ERP-System des Auftraggebers sowie zugehöriger Betriebs- und Wartungsleistungen gemäß dem zwischen den Parteien geschlossenen Service Level Agreement (SLA) zum Betrieb des Beschaffungsagenten, der Bestellung BEST-PROZESSIA-127412 vom 15.06.2026 sowie dem Angebot AG0024 vom 27.05.2026.

(2) Dauer

Die Dauer dieses Vertrags (Laufzeit) entspricht der Laufzeit des zwischen den Parteien bestehenden Service Level Agreements (SLA) zum Betrieb des Beschaffungsagenten. Dieser Vertrag tritt mit Unterzeichnung durch beide Parteien in Kraft, hat eine Mindestlaufzeit von zwölf Monaten und verlängert sich automatisch um jeweils weitere zwölf Monate, sofern er nicht von einer der Parteien schriftlich mit einer Frist von drei Monaten zum jeweiligen Vertragsende gekündigt wird – parallel und gleichlaufend zur Kündigung des SLA. Eine Kündigung dieses Vertrags ist nur gemeinsam mit einer Kündigung des SLA möglich; endet das SLA, endet auch dieser Vertrag zum selben Zeitpunkt. Die Möglichkeit zur fristlosen Kündigung aus wichtigem Grund bleibt hiervon unberührt.

(3) Der Vertrag gilt unbeschadet des vorstehenden Absatzes so lange, wie der Auftragnehmer personenbezogene Daten des Auftraggebers verarbeitet (einschließlich Backups).

(4) Soweit sich aus anderen Vereinbarungen zwischen Auftraggeber und Auftragnehmer anderweitige Abreden zum Schutz personenbezogener Daten ergeben, soll dieser Vertrag zur Auftragsverarbeitung vorrangig gelten, es sei denn die Parteien vereinbaren ausdrücklich etwas anderes.

2. Konkretisierung des Vertragsinhalts

(1) Art und Zweck der vorgesehenen Verarbeitung von Daten

Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich zum Zweck der automatisierten Erkennung, Strukturierung und Weiterverarbeitung von Beschaffungsdokumenten (Auftragsbestätigungen, Lieferscheine, Versanddokumente) des Auftraggebers sowie zum Abgleich dieser Dokumente mit dem ERP-System des Auftraggebers, einschließlich der Nutzung des vom Auftraggeber bereitgestellten und betriebenen Azure OpenAI Service (europäische Region) zur Dokumentenanalyse, der Speicherung und Verarbeitung auf dedizierter Serverinfrastruktur (Hetzner, EU) und der Anbindung per VPN (WireGuard) an das System des Auftraggebers.

(2) Art der Daten

Gegenstand der Verarbeitung personenbezogener Daten sind folgende Datenarten/-kategorien:

- Bestell- und lieferbezogene Sachdaten (Bestellpositionsnummer, Preis, Liefertermin, Menge)

- Firmenbezogene Stammdaten der Lieferanten (Firmenname)

(3) Kategorien betroffener Personen

Die Kategorien der durch die Verarbeitung betroffenen Personen umfassen:

- Lieferanten, soweit es sich um natürliche Personen bzw. Einzelunternehmer handelt (Firmenname als Firma des Einzelunternehmers)
- Mitarbeitende/Ansprechpartner von Lieferanten, soweit deren Name vereinzelt und nicht zweckgerichtet auf den verarbeiteten Dokumenten (z. B. Sachbearbeitervermerk, Unterschrift) genannt ist; dies ist nicht Zweck der Verarbeitung, sondern allenfalls inzidentell der Fall

3. Technisch-organisatorische Maßnahmen

(1) Der Auftragnehmer ergreift in seinem Verantwortungsbereich alle erforderlichen technisch-organisatorischen Maßnahmen gem. Art. 32 DS-GVO zum Schutz der personenbezogenen Daten und übergibt dem Auftraggeber die Dokumentation zur Prüfung [Anlage 1]. Bei Akzeptanz durch den Auftraggeber werden die dokumentierten Maßnahmen Grundlage des Vertrags.

(2) Soweit die Prüfung/ein Audit des Auftraggebers einen Anpassungsbedarf ergibt, ist dieser einvernehmlich umzusetzen.

(3) Die vereinbarten technischen und organisatorischen Maßnahmen unterliegen dem technischen Fortschritt und der Weiterentwicklung. Insoweit ist es dem Auftragnehmer zukünftig gestattet, alternative adäquate Maßnahmen umzusetzen. Dabei darf das Sicherheitsniveau der festgelegten Maßnahmen nicht unterschritten werden. Über wesentliche Änderungen, die durch den Auftragnehmer zu dokumentieren sind, ist der Auftraggeber unverzüglich in Kenntnis zu setzen.

4. Rechte von betroffenen Personen

(1) Der Auftragnehmer unterstützt den Auftraggeber in seinem Verantwortungsbereich und soweit möglich mittels geeigneter technisch-organisatorischer Maßnahmen bei der Beantwortung und Umsetzung von Anträgen betroffener Personen hinsichtlich ihrer Datenschutzrechte. Er darf die Daten, die im Auftrag verarbeitet werden, nicht eigenmächtig, sondern nur nach dokumentierter Weisung des Auftraggebers beaufkunden, portieren, berichtigen, löschen oder deren Verarbeitung einschränken. Soweit eine betroffene Person sich diesbezüglich unmittelbar an den Auftragnehmer wendet, wird der Auftragnehmer dieses Ersuchen unverzüglich an den Auftraggeber weiterleiten.

(2) Soweit vom Leistungsumfang umfasst, sind die Rechte auf Auskunft, Berichtigung, Einschränkung der Verarbeitung, Löschung sowie Datenportabilität nach dokumentierter Weisung des Auftraggebers unmittelbar durch den Auftragnehmer sicherzustellen.

5. Qualitätssicherung und sonstige Pflichten des Auftragnehmers

(1) Der Auftragnehmer hat, zusätzlich zu der Einhaltung der Regelungen dieses Vertrags, eigene gesetzliche Pflichten gemäß der DS-GVO; insofern gewährleistet er insbesondere die Einhaltung folgender Vorgaben:

- a) Die Wahrung der Vertraulichkeit gemäß Artt. 28 Abs. 3 S. 2 lit. b, 29, 32 Abs. 4 DS-GVO. Der Auftragnehmer setzt bei der Durchführung der Arbeiten nur Beschäftigte ein, die auf die Vertraulichkeit verpflichtet und zuvor mit den für sie relevanten Bestimmungen zum Datenschutz vertraut gemacht wurden. Der Auftragnehmer und jede dem Auftragnehmer unterstellte Person, die berechtigterweise Zugang zu personenbezogenen Daten hat, dürfen diese Daten ausschließlich entsprechend der Weisung des Auftraggebers verarbeiten, einschließlich der in diesem Vertrag eingeräumten Befugnisse, es sei denn, dass sie gesetzlich zur Verarbeitung verpflichtet sind.
- b) Der Auftraggeber und der Auftragnehmer arbeiten auf Anfrage mit der Aufsichtsbehörde bei der Erfüllung ihrer Aufgaben zusammen.
- c) Die unverzügliche Information des Auftraggebers über Kontrollhandlungen und Maßnahmen der Aufsichtsbehörde, soweit sie sich auf diesen Vertrag beziehen. Dies gilt auch, soweit eine zuständige Behörde im Rahmen eines Ordnungswidrigkeits- oder Strafverfahrens in Bezug auf die Verarbeitung personenbezogener Daten bei der Auftragsverarbeitung beim Auftragnehmer ermittelt.
- d) Soweit der Auftraggeber seinerseits einer Kontrolle der Aufsichtsbehörde, einem Ordnungswidrigkeits- oder Strafverfahren, dem Haftungsanspruch einer betroffenen Person oder eines Dritten, einem anderen Anspruch oder einem Informationersuchen im Zusammenhang mit

der Auftragsverarbeitung beim Auftragnehmer ausgesetzt ist, hat ihn der Auftragnehmer nach besten Kräften zu unterstützen.

- e) Der Auftragnehmer kontrolliert regelmäßig die internen Prozesse sowie die technischen und organisatorischen Maßnahmen, um zu gewährleisten, dass die Verarbeitung in seinem Verantwortungsbereich im Einklang mit den Anforderungen des geltenden Datenschutzrechts erfolgt und der Schutz der Rechte der betroffenen Person gewährleistet wird.
- f) Nachweisbarkeit der getroffenen technischen und organisatorischen Maßnahmen gegenüber dem Auftraggeber im Rahmen seiner Kontrollbefugnisse nach Ziffer 8 dieses Vertrags.
- g) Der Auftragnehmer meldet Verletzungen des Schutzes personenbezogener Daten unverzüglich an den Auftraggeber in der Weise, dass der Auftraggeber seinen gesetzlichen Pflichten, insbesondere nach Artt. 33, 34 DS-GVO nachkommen kann. Er fertigt über den gesamten Vorgang eine Dokumentation an, die er dem Auftraggeber für weitere Maßnahmen zur Verfügung stellt.
- h) Der Auftragnehmer unterstützt den Auftraggeber in seinem Verantwortungsbereich und soweit möglich im Rahmen bestehender Informationspflichten gegenüber Aufsichtsbehörden und Betroffenen und stellt ihm in diesem Zusammenhang sämtliche relevante Informationen unverzüglich zur Verfügung.
- i) Soweit der Auftraggeber zur Durchführung einer Datenschutz-Folgenabschätzung verpflichtet ist, unterstützt ihn der Auftragnehmer unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen. Gleiches gilt für eine etwaig bestehende Pflicht zur Konsultation der zuständigen Datenschutz-Aufsichtsbehörde.

(2) Dieser Vertrag entbindet den Auftragnehmer nicht von der Einhaltung anderer Vorgaben der DS-GVO.

6. Unterauftragsverhältnisse

(1) Als Unterauftragsverhältnisse im Sinne dieser Regelung sind solche Dienstleistungen zu verstehen, die sich unmittelbar auf die Erbringung der Hauptleistung beziehen. Nicht hierzu gehören Nebenleistungen, die der Auftragnehmer in Anspruch nimmt, z. B. Telekommunikationsleistungen, Post-/Transportdienstleistungen, Reinigungsleistungen oder Bewachungsdienstleistungen. Wartungs- und Prüfleistungen stellen dann ein Unterauftragsverhältnis dar, wenn sie für IT-Systeme erbracht werden, die im Zusammenhang mit einer Leistung des Auftragnehmers nach diesem Vertrag erbracht werden. Der Auftragnehmer ist jedoch verpflichtet, zur Gewährleistung des Datenschutzes und der Datensicherheit der Daten des Auftraggebers auch bei ausgelagerten Nebenleistungen angemessene und gesetzeskonforme vertragliche Vereinbarungen zu treffen sowie Kontrollmaßnahmen zu ergreifen.

(2) Der Auftragnehmer darf Unterauftragnehmer (weitere Auftragsverarbeiter) nur nach vorheriger ausdrücklicher schriftlicher bzw. dokumentierter Zustimmung des Auftraggebers beauftragen. Der Auftraggeber stimmt der Beauftragung der in Anhang 2 bezeichneten Unterauftragnehmer unter der Bedingung einer vertraglichen Vereinbarung nach Maßgabe des Art. 28 Abs. 2–4 DS-GVO mit dem Unterauftragnehmer zu. Die vertragliche Vereinbarung wird dem Auftraggeber auf dessen Verlangen vorgelegt, wobei geschäftliche Klauseln ohne datenschutzrechtlichen Bezug hiervon ausgenommen sind.

Die Auslagerung auf Unterauftragnehmer oder der Wechsel der gemäß Anhang 2 bestehenden Unterauftragnehmer sind zulässig, soweit:

- der Auftragnehmer eine solche Auslagerung auf Unterauftragnehmer dem Auftraggeber in einer angemessenen Zeit, die 14 Tage nicht unterschreiten darf, vorab schriftlich oder in Textform anzeigt und
- der Auftraggeber nicht bis zum Zeitpunkt der Übergabe der Daten gegenüber dem Auftragnehmer schriftlich oder in Textform Einspruch gegen die geplante Auslagerung erhebt und
- eine vertragliche Vereinbarung nach Maßgabe des Art. 28 Abs. 2–4 DS-GVO zugrunde gelegt wird.

(3) Die Weitergabe von personenbezogenen Daten des Auftraggebers an den Unterauftragnehmer und dessen erstmaliges Tätigwerden sind erst mit Vorliegen aller Voraussetzungen für eine Unterbeauftragung gestattet. Die Einhaltung und Umsetzung der technisch-organisatorischen Maßnahmen beim Unterauftragnehmer wird unter Berücksichtigung des Risikos vorab der Verarbeitung personenbezogener Daten und sodann regelmäßig durch den Auftragnehmer kontrolliert. Der Auftragnehmer stellt dem Auftraggeber die Kontrollergebnisse auf Anfrage zur Verfügung. Der Auftragnehmer stellt ferner sicher, dass der Auftraggeber seine Rechte aus dieser Vereinbarung (insbesondere seine Kontrollrechte) auch direkt gegenüber den Unterauftragnehmern wahrnehmen kann.

(4) Erbringt der Unterauftragnehmer die vereinbarte Leistung außerhalb der EU/des EWR, stellt der Auftragnehmer die datenschutzrechtliche Zulässigkeit durch entsprechende Maßnahmen sicher. Gleiches gilt, wenn Dienstleister im Sinne von Abs. 1 Satz 2 eingesetzt werden sollen.

(5) Eine weitere Auslagerung durch den Unterauftragnehmer bedarf der ausdrücklichen Zustimmung des Hauptauftraggebers (mind. Textform). Sämtliche vertraglichen Regelungen in der Vertragskette sind auch dem weiteren Unterauftragnehmer aufzuerlegen.

7. Internationale Datentransfers

(1) Jede Übermittlung personenbezogener Daten in ein Drittland oder an eine internationale Organisation bedarf einer dokumentierten Weisung des Auftraggebers und bedarf der Einhaltung der Vorgaben zur Übermittlung personenbezogener Daten in Drittländer nach Kapitel V der DS-GVO.

Die Erbringung der vertraglich vereinbarten Datenverarbeitung findet ausschließlich in einem Mitgliedsstaat der Europäischen Union oder in einem anderen Vertragsstaat des Abkommens über den Europäischen Wirtschaftsraum statt. Eine Datenübermittlung in ein Drittland ist im Rahmen dieses Vertrags nicht vorgesehen. Sämtliche eingesetzten Auftragsverarbeiter/Unterauftragsverarbeiter (einschließlich des in Anlage 2 genannten Cloud-KI-Dienstes) verarbeiten die Daten ausschließlich in Rechenzentren innerhalb der EU/des EWR.

(2) Soweit der Auftraggeber eine Datenübermittlung an Dritte in ein Drittland anweist, ist er für die Einhaltung von Kapitel V der DS-GVO verantwortlich.

8. Kontrollrechte des Auftraggebers

(1) Der Auftraggeber hat das Recht, im Benehmen mit dem Auftragnehmer Überprüfungen durchzuführen oder durch im Einzelfall zu benennende Prüfer durchführen zu lassen. Er hat das Recht, sich durch

Stichprobenkontrollen, die in der Regel rechtzeitig anzumelden sind, von der Einhaltung dieser Vereinbarung durch den Auftragnehmer in dessen Geschäftsbetrieb während der üblichen Geschäftszeiten zu überzeugen.

(2) Der Auftragnehmer stellt sicher, dass sich der Auftraggeber von der Einhaltung der Pflichten des Auftragnehmers nach Art. 28 DS-GVO überzeugen kann. Der Auftragnehmer verpflichtet sich, dem Auftraggeber auf Anforderung die erforderlichen Auskünfte zu erteilen und insbesondere die Umsetzung der technischen und organisatorischen Maßnahmen nachzuweisen.

(3) Der Nachweis der technisch-organisatorischen Maßnahmen zur Einhaltung der besonderen Anforderungen des Datenschutzes allgemein sowie solche, die den Auftrag betreffen, kann erfolgen durch:

- die Einhaltung genehmigter Verhaltensregeln gemäß Art. 40 DS-GVO;
- die Zertifizierung nach einem genehmigten Zertifizierungsverfahren gemäß Art. 42 DS-GVO;
- aktuelle Testate, Berichte oder Berichtsauszüge unabhängiger Instanzen (z. B. Wirtschaftsprüfer, Revision, Datenschutzbeauftragter, IT-Sicherheitsabteilung, Datenschutzauditoren, Qualitätsauditoren);
- eine geeignete Zertifizierung durch IT-Sicherheits- oder Datenschutzaudit (z. B. nach BSI-Grundschutz).

9. Weisungsbefugnis des Auftraggebers

(1) Der Auftragnehmer verarbeitet personenbezogene Daten nur auf Basis dokumentierter Weisungen des Auftraggebers, es sei denn er ist nach dem Recht des Mitgliedstaats oder nach Unionsrecht zu einer Verarbeitung verpflichtet. Mündliche Weisungen bestätigt der Auftraggeber unverzüglich (mind. Textform). Die anfänglichen Weisungen des Auftraggebers werden durch diesen Vertrag festgelegt.

(2) Der Auftragnehmer hat den Auftraggeber unverzüglich zu informieren, wenn er der Meinung ist, eine Weisung verstoße gegen Datenschutzvorschriften. Der Auftragnehmer ist berechtigt, die Durchführung der entsprechenden Weisung solange auszusetzen, bis sie durch den Auftraggeber bestätigt oder geändert wird.

10. Löschung und Rückgabe von personenbezogenen Daten

(1) Kopien oder Duplikate der Daten werden ohne Wissen des Auftraggebers nicht erstellt. Hiervon ausgenommen sind Sicherheitskopien, soweit sie zur Gewährleistung einer ordnungsgemäßen Datenverarbeitung erforderlich sind, sowie Daten, die im Hinblick auf die Einhaltung gesetzlicher Aufbewahrungspflichten erforderlich sind.

(2) Nach Abschluss der vertraglich vereinbarten Arbeiten oder früher nach Aufforderung durch den Auftraggeber – spätestens aber mit Beendigung des SLA – hat der Auftragnehmer sämtliche in seinen Besitz gelangten Unterlagen, erstellte Verarbeitungs- und Nutzungsergebnisse sowie Datenbestände, die im Zusammenhang mit dem Auftragsverhältnis stehen, dem Auftraggeber auszuhändigen oder nach vorheriger Zustimmung datenschutzgerecht zu vernichten. Gleiches gilt für Test- und Ausschussmaterial. Das Protokoll der Löschung ist auf Anforderung vorzulegen.

Anlage 1 — Technisch-organisatorische Maßnahmen

Beschreibung der technisch-organisatorischen Maßnahmen des Auftragnehmers unter Berücksichtigung der Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere des Risikos für die Rechte und Freiheiten betroffener Personen.

Pseudonymisierung/Verschlüsselung

Die Datenverarbeitung erfolgt über einen mittels WireGuard-VPN verschlüsselten Tunnel zwischen der Serverinfrastruktur des Auftragnehmers und dem ERP-System des Auftraggebers. Daten werden sowohl bei der Übertragung (Transportverschlüsselung, TLS) als auch bei der Speicherung (Encryption at Rest) verschlüsselt.

Vertraulichkeit, Integrität, Verfügbarkeit, Belastbarkeit

Die Verarbeitung erfolgt auf dedizierten, ausschließlich für den Auftraggeber eingerichteten virtuellen Servern (Hetzner Cloud, Rechenzentrum EU) mit Containerisierung (Docker) und Reverse-Proxy mit automatischer TLS-Verschlüsselung (Traefik). Der Zugriff auf Verwaltungsoberflächen erfolgt ausschließlich über den verschlüsselten VPN-Tunnel.

Verfügbarkeit und Wiederherstellbarkeit

Regelmäßige automatisierte Backups der Datenbanken und Konfigurationen; Monitoring der Serverinfrastruktur und Dienste mittels Uptime Kuma zur frühzeitigen Erkennung von Ausfällen.

Überprüfung und Evaluierung

Regelmäßige Überprüfung der Server- und Zugriffskonfiguration durch den Auftragnehmer; Versionierung und Nachvollziehbarkeit von Konfigurationsänderungen über Git/GitHub.

Identifizierung und Authentifizierung von Nutzern

Zugriff auf Server und Verwaltungssysteme (z. B. Portainer) ausschließlich per personalisierten Zugangsdaten und schlüsselbasierter Authentifizierung (SSH-Key); kein Zugriff über Passwort-Authentifizierung auf Serverebene.

Schutz bei Übertragung

Die Anbindung an das ERP-System des Auftraggebers erfolgt ausschließlich über einen dedizierten, verschlüsselten WireGuard-VPN-Tunnel; sämtliche übrige Kommunikation erfolgt über TLS-verschlüsselte Verbindungen (HTTPS).

Schutz bei Speicherung

Daten werden ausschließlich auf dem für den Auftraggeber dedizierten Server gespeichert (kein Mandanten-Mixing); Datenbankzugriffe sind durch Zugriffskontrolle auf Anwendungsebene beschränkt.

Physische Sicherheit

Die physische Sicherheit der Serverstandorte wird durch den Hosting-Anbieter (Hetzner Online GmbH, Rechenzentren in Deutschland/EU) gewährleistet (Zugangskontrolle, Videoüberwachung, redundante Stromversorgung gemäß den Angaben des Anbieters).

Heim- und Telearbeit

Die Verarbeitung von Daten, die diesem Vertrag unterliegen, ist auch im Rahmen von Heim- bzw. Telearbeit der Mitarbeitenden des Auftragnehmers gestattet; der Zugriff erfolgt stets über verschlüsselte Verbindungen (VPN/TLS) und personalisierte Zugangsdaten.

Ereignisprotokollierung

Server- und Anwendungszugriffe werden protokolliert (Logging); Authentifizierungsversuche und sicherheitsrelevante Ereignisse werden über das Monitoring-System erfasst.

Unterstützung bei Betroffenenrechten

Der Auftragnehmer stellt sicher, dass Daten gezielt identifiziert, exportiert oder gelöscht werden können, um Anfragen betroffener Personen (Auskunft, Löschung, Berichtigung) auf Weisung des Auftraggebers zeitnah umzusetzen.

Anlage 2 — Genehmigter Unterauftragnehmer

Der Auftragnehmer setzt für die Bereitstellung der virtuellen Serverinfrastruktur (Hosting) zum Betrieb des Beschaffungsagenten folgenden Unterauftragnehmer ein:

Hetzner Online GmbH, Deutschland.

Die Verarbeitung erfolgt ausschließlich in einem Rechenzentrum in Deutschland; ein Drittlandtransfer findet insoweit nicht statt.

Hinweis: Der vom Auftraggeber selbst bereitgestellte und betriebene Azure OpenAI Service (eigener Microsoft-Account des Auftraggebers) stellt keinen Unterauftragnehmer des Auftragnehmers im Sinne dieses Vertrags dar, da der Auftraggeber insoweit unmittelbar Vertragspartner von Microsoft ist und die Datenverarbeitung im eigenen Verantwortungsbereich des Auftraggebers erfolgt.

An dieser Stelle kommen insbesondere die Standarddatenschutzklauseln der Kommission gem. Art. 46 Abs. 2 lit. c DS-GVO in der Variante „Übermittlung von Auftragsverarbeiter an Auftragsverarbeiter“ (Modul 3) in Betracht.

Saarbrücken, den _____

Schaufler Tooling GmbH & Co. KG

Prozessia GbR